

ISO/IEC 27001 Interview Preparation Questions

1. General / Basic Questions

- What is ISO/IEC 27001, and what is its main objective?
- What are the three pillars of information security?
- How does ISO 27001 relate to ISO 27002?
- What is an Information Security Management System (ISMS)?
- What are the benefits of implementing ISO 27001?
- Who issues the ISO 27001 certification?
- What are the key clauses of ISO 27001:2022?
- What is the difference between compliance and certification in ISO 27001?
- What is the Plan-Do-Check-Act (PDCA) cycle, and how does ISO 27001 align with it?
- What are “interested parties” under Clause 4.2, and why are they important?

2. ISMS Scope & Context

- What factors influence the scope of an ISMS?
- How do you define the boundaries and applicability of the ISMS?
- How do you handle shared environments or cloud services within the ISMS scope?
- Can you give an example of internal and external issues relevant to an ISMS?
- What is the importance of leadership commitment in ISO 27001?

3. Risk Assessment & Treatment

- What are the steps in performing an ISO 27001 risk assessment?
- How do you determine the risk appetite of an organization?
- What is the difference between a risk owner and a control owner?
- What are the main components of a risk treatment plan?
- How do you select controls from Annex A?
- What's the difference between inherent risk and residual risk?
- How does ISO 27005 support ISO 27001 implementation?
- How do you evaluate the effectiveness of risk treatments?

4. Annex A Controls (2022 Version)

- What are the 4 control themes in ISO 27001:2022 Annex A?
- Name examples of organizational controls.
- How do controls A.5.7 (Threat intelligence) and A.5.23 (Information security for use of cloud services) differ?
- What are key controls for access management?
- How does control A.8.28 (Secure coding) apply to DevSecOps?
- How would you implement control A.5.30 (ICT readiness for business continuity)?
- What is the purpose of A.5.36 (Compliance with policies and standards for information security)?

5. Documentation & Evidence

- What are mandatory documents required by ISO 27001?
- What is a Statement of Applicability (SoA), and what is its purpose?
- How often should ISMS policies and procedures be reviewed?
- How do you maintain document control within an ISMS?
- What's the difference between documented information and records in ISO 27001 terminology?

6. Monitoring, Auditing & Improvement

- What are the requirements for internal audits under ISO 27001?
- How would you prepare an internal audit plan?
- What are the inputs and outputs of the management review process?
- What's the difference between nonconformity and observation in an audit?
- How do you identify and address continual improvement opportunities?
- What are common nonconformities found during ISO 27001 audits?

7. Advanced / Scenario-Based Questions

- You discover that an access control policy exists, but user access reviews haven't been performed for 12 months. How would you handle this?
- How would you integrate ISO 27001 controls with NIST CSF or ISO 27701?
- Describe how to implement a risk-based approach to vendor management under ISO 27001.
- Your company uses multiple SaaS platforms. How would you ensure compliance with A.5.23 (Cloud services)?
- How would you demonstrate continual improvement to an external auditor?
- How do you align ISO 27001 with business continuity and incident management processes?
- How would you approach the transition from ISO 27001:2013 to ISO 27001:2022?

8. For Lead Implementer or Auditor Roles

- What are the steps to achieve ISO 27001 certification?
- How would you perform a gap assessment against ISO 27001:2022?
- How do you ensure impartiality and objectivity during an internal audit?
- What's the difference between a major and minor nonconformity?
- What's the role of Top Management in the certification process?
- How would you communicate ISMS performance metrics to leadership?